

MAPEO DETALLADO: PREGUNTAS GQM → REQUISITOS NORMATIVOS

MITRE ATLAS | Ciberseguridad IA España 2026

Versión: 1.0

Clasificación: Público - Técnico

Fecha: Enero 2026

RESUMEN EJECUTIVO

Este documento mapea cada una de las **4 Questions (Q1-Q4)** del framework GQM contra requisitos específicos de:

- **AI Act EU 2024/1689** (Vigente agosto 2025)
- **NIS2 / Directiva 2022/2555** (Transposición completa octubre 2024)
- **AIDA español** (Aprobada marzo 2025)
- **RGPD 2018** (Vigente, aplicable datos)
- **CMMC 2.0 / NIST CSF 2.0** (Frameworks referencia)

Propósito: Asegurar que indicadores ATLAS responden directamente a **requisitos regulatorios de cumplimiento nacional + europeo**.

TABLA 1: Q1 (VISIBILIDAD AMENAZAS) → NORMATIVA

QUESTION 1: "¿Cuáles son las amenazas MITRE ATLAS más críticas y prevalentes?"

Requisito Normativo	Marco	Artículo/Ref	Descripción Requisito	Métrica ATLAS Asociada	Evidencia Cumplimiento
Risk Assessment de Sistemas IA Alto-Riesgo	AI Act EU	Art. 6	Identificar riesgos específicos amenazas adversariales alto-riesgo	M1.1 Índice Prevalencia Tácticas	Lista tácticas ATLAS prevalentes España por sector
Análisis Amenazas Sector-Específicas	NIS2	Art. 18-20	Operadores esenciales deben mapear amenazas sectoriales	M1.2 Matriz Criticidad Sectorial	Ranking tácticas criticidad × 7 sectores
Monitoreo Evolución Amenaza	CCN / CSIRT	Documento de referencia	Mantener inteligencia amenazas actualizada	M1.3 Evolución YoY	Tendencia % incidentes IA año-a-año
Análisis Impacto por Tamaño Org	NIS2 Art. 21	Diferenciación PYME vs. grande	Requisitos proporcionales tamaño	M1.4 Distribución Tamaño Víctimas	% incidentes por rango empleados
Mapping ATLAS a ATT&CK National	ENISA / CCN	Recomendación técnica	Correlacionar ATLAS con ATT&CK ATT&CK para contexto global	M1.1-M1.4 Agregado	Cross-mapping tácticas ATLAS ↔ ATT&CK

Requisitos Específicos Q1 Cumplimiento

Requisito	Evidencia Requerida	Frecuencia	Propietario
Identificar top-3 tácticas por sector	Reporte M1.1-M1.2	Anual	CCN / INCIBE
Detectar tendencias emergentes	Tendencia M1.3	Trimestral	CSIRT
Validar cobertura PYME	Análisis M1.4 sesgo	Semestral	AESIA
Publicar inteligencia amenazas	Documento público + base datos	Anual	CCN

TABLA 2: Q2 (MADUREZ DEFENSIVA) → NORMATIVA

QUESTION 2: "¿Cuál es la postura defensiva actual (madurez) por organización?"

Requisito Normativo	Marco	Artículo/Ref	Descripción Requisito	Métrica ATLAS Asociada	Evidencia Cumplimiento
Auditoría Ciberseguridad IA Periódica	AI Act	Art. 14-15	Validar defensas sistemas alto-riesgo anualmente	M2.1 Score Madurez IA (0-100)	Score agregado 13 dimensiones
Evaluación Riesgos Conforme NIST	NIS2	Art. 20	Usar frameworks establecidos (NIST, ISO, COBIT)	M2.3-M2.6 Sub-scores GOVERN/MAP/MEASURE/MANAGE	Mapeo 100 controles NIST
Análisis Brechas Gobernanza IA	AIDA	Artículos capítulo II	Gobernanza, transparencia, rendición cuentas	M2.3 Score GOVERN	Policy IA, estructura CISO, reporting board
Mapeo Activos Críticos + Dependencias	NIS2 Art. 19	Inventario + evaluación criticidad	M2.4 Score MAP	Catálogo sistemas IA, matriz criticidad	
Capacidad Monitoreo Continuo	NIST CSF 2.0	Función DETECT	Monitoreo tiempo real amenazas	M2.5 Score MEASURE	% cobertura SIEM, alertas integradas
Respuesta Incidentes Efectiva	NIS2 Art. 21(3)	Reportar 72h + análisis post-mortem	M2.6 Score MANAGE	Planes IRP, CSIRT, MTTC/MTTR	
Brecha entre PYME y Grandes	NIS2 Art. 21(1)	Requerimientos proporcionales	M2.7 Brecha PYME-Grande	Análisis diferencia score	

Requisitos Específicos Q2 Cumplimiento

Requisito	Evidencia Requerida	Target/SLA	Propietario
Score Madurez ≥70/100	M2.1 baseline	Dic 2026	CISO nacional
100% Orgs críticas auditadas	M2.1 cobertura	Jun 2026	AESIA
Brecha PYME reducida ≥10%	M2.7 mejora	Dic 2027	INCIBE + mineco
Reportes sectoriales públicos	M2.1-M2.6 desagregados	Anual	AESIA

TABLA 3: Q3 (CAPACIDAD DETECCIÓN) → NORMATIVA

QUESTION 3: "¿Qué capacidad de detección de amenazas IA existe?"

Requisito Normativo	Marco	Artículo/Ref	Descripción Requisito	Métrica ATLAS Asociada	Evidencia Cumplimiento
Detección Oportuna Incidentes	NIS2 Art. 23(1)	"La mayor brevedad posible"	M3.1 MTTD (Mean Time To Detect)	Tiempo promedio detección <4h objetivo	
Integración SIEM Obligatoria	CMMC 2.0 / NIST	AC-2, SI-4	Logging centralizado + correlación	M3.2 % Orgs con SIEM	% implementación SIEM operativo
Análisis Comportamiento Usuarios (UEBA)	NIS2 + PSD2	Detección anomalías	M3.3 % Orgs con UEBA	% análisis comportamiento integrado	
Inteligencia Amenazas Específica IA	ENISA / CCN	Recomendación técnica	Threat intel ATLAS actualizado	M3.4 % Threat Intel IA-specific	% orgs con feeds amenazas IA
Cobertura Defensas ATLAS Técnicas	MITRE ATLAS	66 técnicas mapeadas	Detectar/ defender contra técnicas conocidas	M3.5 Cobertura Técnicas ATLAS	% técnicas con detección conocida
Latencia Generación Alerta	SOC SLA estándar	<30 min (objetivo)	Rapidez análisis evento – alerta	M3.6 Latencia Alerta	Tiempo promedio evento-alerta (minutos)
Precisión Alertas (Falsos Positivos)	SOC operacional	<15% objetivo	Minimizar ruido alertas	M3.7 Tasa Falsos Positivos	% alertas IA verdadero positivo

Requisitos Específicos Q3 Cumplimiento

Requisito	Evidencia Requerida	Target SLA	Propietario
MTTD <4 horas críticas	M3.1 medición	2026 baseline	CSIRT nacional
100% orgs esenciales SIEM	M3.2 auditoría	Jun 2026	AESIA
Cobertura ≥70% técnicas ATLAS	M3.5 inventario	Dic 2026	INCIBE
Falsos positivos <15%	M3.7 análisis	Continuo	SOC sector

TABLA 4: Q4 (CONFORMIDAD NORMATIVA) → NORMATIVA

QUESTION 4: "¿Qué % organizaciones cumple requisitos normativos?"

Requisito Normativo	Marco	Artículo/Ref	Descripción Requisito	Métrica ATLAS Asociada	Evidencia Cumplimiento
Cumplimiento AI Act Alto-Riesgo	AI Act EU	Art. 3-6	Requisitos sistemas clasificados alto-riesgo	M4.1 % Conformidad AI Act	Checklist 40+ requisitos implementados
Cumplimiento 100 Controles NIS2	NIS2 Annex II	100 controles NIST	Implementar controles mapeados NIS2	M4.2 % Conformidad NIS2	Audit trail controles operativos
Mapeo ATLAS → NIST 800-53	NIST / ATLAS	Cross-mapping	Correlacionar técnicas adversariales con controles NIST	M4.3 Mapeo ATLAS-NIST	% técnicas ATLAS con control NIST
Auditorías Supervisión AESIA	AESIA / NIS2	Art. 33-34	Auditorías regularidad supervisión entidades críticas	M4.4 % Orgs Evaluadas AESIA	Nº orgs auditadas / total críticas
Hallazgos Auditoría Críticos	AESIA Metodología	Clasificación severidad	Tracking resolución hallazgos críticos	M4.5 Hallazgos Críticos/Altos	Nº absoluto hallazgos críticos abiertos
Privacidad Datos (RGPD)	RGPD	Art. 5-7, 32-33	Confidencialidad, integridad datos IA	M2.5 (Score MEASURE privacidad)	Encriptación, DLP, auditoría acceso
Transparencia IA (AIDA)	AIDA	Art. 10-13	Revelación sistemas IA, sesgos, explicabilidad	M2.3 (Score GOVERN transparencia)	Documentación públicas sistemas IA

Requisitos Específicos Q4 Cumplimiento

Requisito	Evidencia Requerida	Deadline	Propietario
≥80% conformidad AI Act alto-riesgo	M4.1 auditoría	Dic 2026	AESIA
100% conformidad NIS2 criterios	M4.2 checklist	Dic 2026	CISO sector
Mapeo 100% ATLAS→NIST	M4.3 base datos	Mar 2026	INCIBE
Auditorías ≥50% orgs críticas	M4.4 cobertura	Jun 2026	AESIA
Resolución hallazgos <90 días	M4.5 tracking	Continuo	CISO sector

TABLA 5: MATRIZ INTEGRADA PREGUNTAS → NORMATIVA → INDICADORES

Question GQM	Preguntas	Tácticas ATLAS Asociadas	Marcos Normativos	Indicadores ATLAS (M#. #)	Stakeholder Primario	Frequency
Q1: Visibilidad Amenazas	¿Amenazas prevalentes?	AML.TA000 1-0015 (todas 15)	AI Act, NIS2, ENISA	M1.1, M1.2, M1.3, M1.4	CCN / INCIBE	Anual
Q2: Madurez Defensiva	¿Postura defensiva?	AML.TA000 7 (Defense Evasion) + todas	AI Act, NIS2, AIDA, NIST CSF	M2.1-M2.7	AESIA / CISOs	Anual
Q3: Detección	¿Detectamos rápido?	AML.TA000 3, TA0011 (C2)	NIS2, CMMC 2.0, NIST SI-4	M3.1-M3.7	CSIRT / SOC	Trimestral
Q4: Conformidad	¿Cumplimos reqs?	Según reqs específicos	AI Act, NIS2, AIDA, RGPD	M4.1-M4.5	AESIA / DPO	Semestral

TABLA 6: MAPEO CONTROLES NIST CSF 2.0 → INDICADORES ATLAS

NIST CSF Function	Control Específico	Descripción	Métrica ATLAS	AI Act Art	NIS2 Art
GOVERN	GV.RO-01	Estructura gobernanza riesgos	M2.3 Score GOVERN	Art. 14	Art. 20
GOVERN	GV.RM-02	Risk assessment materiales	M2.3 + M1.1	Art. 6	Art. 20
GOVERN	GV.RM-03	Risk management proceso	M2.3 + M2.6	Art. 14-15	Art. 20
MAP	MAP-DW-01	Data + workflows inventory	M2.4 Score MAP	Art. 4	Art. 19
MAP	MAP-DW-02	Asset criticality	M2.4 + M1.2	Art. 6	Art. 19
MEASURE	ME-TI-01	Threat intelligence	M3.4 Threat Intel	Art. 28	Art. 23
MEASURE	ME-TI-02	Anomaly detection	M3.3 UEBA + M3.5 Cobertura	Art. 28	Art. 23
MEASURE	ME-TI-03	Incident detection	M3.1 MTTD	Art. 29	Art. 23
MANAGE	MG-IR-01	Incident response plan	M2.6 Score MANAGE	Art. 29	Art. 21
MANAGE	MG-IR-02	Response effectiveness	M3.1 MTTC/MTTR	Art. 29	Art. 21

TABLA 7: REQUISITOS ESPECÍFICOS POR MARCO NORMATIVO

AI ACT EU (2024/1689) - ALTO RIESGO

Artículo	Requisito	Métricas ATLAS	Verificación
Art. 3	Definir sistema alto-riesgo	M2.1, M2.4	Clasificación sistemas IA
Art. 6	Risk assessment adversarial	M1.1, M1.2, M2.3	Documentación análisis riesgos
Art. 14	Riesgos seguridad cibernética	M2.3, M2.5, M3.1	Evaluación defensas
Art. 15	Medidas mitigación riesgos	M2.1-M2.6	Controles implementados
Art. 28	Threat intel + monitoreo	M3.4, M3.1, M3.5	Feed inteligencia, alertas
Art. 29	Incident reporting	M4.5, M3.1, M2.6	Reportes <72h

NIS2 (Directiva 2022/2555) - OPERADORES ESENCIALES

Artículo	Requisito	Métricas ATLAS	Verificación
Art. 19	Inventario activos críticos	M2.4 Score MAP	Catálogo sistemas IA
Art. 20	Risk management framework	M2.1, M2.3	Governance doc + SOP
Art. 21	Medidas seguridad técnicas	M2.1-M2.6	Implementación controles
Art. 23	Detección incidents	M3.1 MTTD	SLA <4h objetivo
Art. 33	Auditorías AESIA	M4.4	Calendario auditorías

AIDA ESPAÑA (2025) - TRANSPARENCIA IA

Capítulo	Requisito	Métricas ATLAS	Verificación
Cap. II	Gobernanza sistemas IA	M2.3 Score GOVERN	Políticas, estructura
Cap. III	Prohibiciones identif. biométrica	M2.4 (asset inventory)	Audit trail negación
Cap. IV	Evaluación sesgo / fairness	M2.3 + M4.1	Testing algorithms
Cap. V	Transparencia operativa	M2.3 Transparencia	Documentación pública

TABLA 8: TIMELINE IMPLEMENTACIÓN NORMATIVA

Trimestre	Hito Regulatorio	Métricas Requeridas	Objetivo Cumplimiento
Q1 2026	Transposición NIS2 final	M1.1-M1.4, M4.2	Baseline nacional
Q2 2026	Auditorías AESIA iniciales	M2.1, M4.4	≥50% cobertura críticas
Q3 2026	AI Act validación sistemas alto-riesgo	M4.1, M2.3	80% conformidad objetivo
Q4 2026	AIDA implementación plena	M2.3, M4.5	Documentación completada
Q1 2027	Revisión anual NIS2 + AI Act	M1.1-M4.5 agregado	Mejora vs. 2026 baseline

CONCLUSIÓN

Este mapeo asegura **trazabilidad completa** entre:

- **Requisitos normativos europeos + españoles** (AI Act, NIS2, AIDA, RGPD)

- **Indicadores MITRE ATLAS** (24 métricas M1.1-M4.5)
- **Controles técnicos** (NIST CSF, CMMC 2.0)
- **Stakeholders supervisión** (AESIA, CCN, INCIBE, CISOs)

Resultado: Cada indicador ATLAS responde directamente a requisito normativo específico, validado y auditable.

Documento preparado: Enero 2026

Clasificación: Público - Técnico

Próxima revisión: Trimestral (actualizaciones normativas)